

Sri Lanka Institute of Information Technology



Enterprise Standards for Information Security - IE3102

Statement of Applicability (SoA)

IT23269484 – T. H. Ranasinghe

1. Introduction

The Statement of Applicability (SoA) is one of the most critical and auditable documents in an Information Security Management System (ISMS). Under Clause 6.1.3(d) of ISO/IEC 27001:2022, the SoA must identify all controls from Annex A, specify whether each is applicable, and justify its inclusion or exclusion. It also records the implementation status of each control and provides traceability to risk assessment results and treatment plans.

The ISO/IEC 27001:2022 standard, updated to address global cybersecurity challenges and enhance digital trust groups its 93 controls into four domains Organizational, People, Physical, and Technological. SoA ensures that each of these domains is considered in relation to business risks, thereby turning the ISMS into an evidence-based governance system.

The SoA transforms ISO's theoretical requirements into a verifiable control framework, aligning "planning," "operation," and "checking" stages within the PDCA model.

2. Purpose and Significance

The SoA is not merely a checklist, it is a strategic management document that connects three ISMS pillars:

- Risk Assessment: Identifies and evaluates information security risks.
- Risk Treatment Plan (RTP): Specifies actions and chosen controls to address these risks.
- Statement of Applicability: Documents which Annex A controls have been selected, why, and how they are implemented.

Primary purposes include:

1. Providing evidence of risk-based decision-making and justification for control selections.
2. Demonstrating compliance to auditors, clients, and regulators.
3. Enabling systematic internal review of the ISMS.
4. Supporting continual improvement through periodic updates.

Risk-based control decisions should remain dynamic reflecting the organization's evolving threat landscape and operational environment.

3. Relationship with ISO Clauses

The SoA directly supports the following ISO/IEC 27001:2022 clauses:

Clause	Description	SoA Contribution
4	Context of the Organization	Identifies internal/external issues impacting control selection.
5	Leadership	Provides assurance of management's approval and accountability for controls.
6	Planning	Records risk treatment results and applicable Annex A controls.
7	Support	Ensure documented information is available, controlled, and maintained.
8	Operation	Links controls to operational risk mitigation.
9	Performance Evaluation	Acts as evidence during audits and internal reviews.
10	Improvement	Provides data for corrective and preventive actions based on gaps found.

4. Structure of the Statement of Applicability

A standard SoA is presented in a tabular format that includes the following elements:

Control ID	Control Title / Description	Applicability (Y/N)	Implementation Status	Justification for Inclusion or Exclusion	Related Risk ID	Evidence / Reference Document
A.5.1	Information Security Policies	Y	Implemented	Policy aligns with strategic security objectives.	R01	Information Security Policy V2.
A.8.3	Information Transfer	Y	In progress	Controls needed for data exchange with vendors.	R05	Vendor Security Guideline.
A.9.4	Access Control	Y	Implemented	Access control essential for confidential HR data.	R09	Access Control Matrix V1.
A.14.1	Secure Development	N	Excluded	No internal software development activities.	R12	—

This layout ensures that every Annex A control is reviewed, documented, and justified showing auditors that decisions are risk-based, not arbitrary.

5. Methodology for Developing the SoA

Step 1 - Input from Risk Assessment

Each risk identified during assessment is mapped to potential control categories from Annex A. For instance, if “unauthorized access to financial records” is a risk, controls such as A.5 (Information Security Policies), A.9 (Access Control), and A.10 (Cryptography) are considered.

Step 2 - Risk Treatment and Control Selection

Based on the risk level (High/Medium/Low), the appropriate control is selected, justified, and documented.

This process exemplifies risk-oriented thinking, ensuring that ISMS controls are preventive, not reactive.

Step 3 - Management Approval

Leadership validates control inclusion, confirming alignment with business strategy and budget. Management endorsement ensures traceability and accountability under Clause 5 (Leadership).

Step 4 - Implementation and Verification

Each control must have measurable evidence (logs, configurations, or policies). Controls under implementation are monitored until full compliance is achieved.

Step 5 - Maintenance and Review

SoA must be reviewed at least annually or after major organizational changes. All revisions should be version-controlled and approved by the ISMS Manager.

6. Integration with PDCA Cycle

PDCA model:

- Plan: Identify risks and select applicable controls.
- Do: Implement and document them in the SoA.
- Check: Audit control effectiveness and compliance.
- Act: Revise and enhance the SoA after management reviews.

This cycle ensures that the SoA remains a living document, continuously improving alongside the ISMS.

7. Control Domains under ISO/IEC 27001:2022

Four newly consolidated control domains in Annex A of ISO/IEC 27001:2022:

- Organizational Controls (A.5–A.7) - governance, policy management, supplier relationships.
- People Controls (A.8) - training, awareness, role management, and confidentiality obligations.
- Physical Controls (A.9) - physical access restrictions, equipment security, and environmental safeguards.
- Technological Controls (A.10) - encryption, network security, system acquisition, and secure coding.

These domains replace the earlier 14 categories of ISO/IEC 27001:2013 and align with the NIST Cybersecurity Framework functions (Identify, Protect, Detect, Respond, Recover).

8. Sample SoA Excerpt with ISO 27001:2022 Controls

Control No.	Control Title	Applicability	Implementation Status	Justification	Mapped NIST Function
A.5.7	Threat Intelligence	Y	Implemented	Provides situational awareness to anticipate attacks.	Identify / Protect
A.5.23	Information Security for Use of Cloud Services	Y	In Progress	Cloud-based data storage requires security controls.	Protect
A.7.4	Physical Security Monitoring	Y	Implemented	New ISO 2022 control ensuring camera and access logs.	Detect
A.8.16	Data Leakage Prevention	Y	Implemented	Prevents unauthorized data transmission and loss.	Protect / Detect
A.8.29	Secure Coding	N	Excluded	No in-house software development activity.	—

These examples illustrate how new controls introduced in 2022 such as cloud security, data masking, and threat intelligence are integrated within the SoA framework to demonstrate the organization's cyber resilience maturity.

9. Maintenance and Version Control

An SoA must be reviewed annually or after significant events, such as technological upgrades or organizational restructuring. Each review should document:

- New controls introduced by ISO amendments.
- Changes in risk ratings after incident investigations.
- Decommissioned assets or systems.
- Audit findings requiring control enhancements.

Ineffective document control is major implementation problem organizations often retain outdated SoAs. To overcome this, a digital document management system with versioning and electronic approval should be adopted.

10. Interconnections with Other ISMS Documents

ISMS Document	Connection to SoA
Risk Assessment Report	Identifies risks to be mitigated by controls listed in SoA.
Risk Treatment Plan	Specifies the implementation actions for selected controls.
Asset Registry	Provides asset classification and ownership used to determine control relevance.
Internal Audit Plan	Uses the SoA as the master checklist for audit scope.
Management Review Minutes	Record decisions for updating the SoA based on performance and incidents.

The SoA therefore acts as the nerve center linking all ISMS documentation.

11. Audit and Compliance Function

During internal and external audits, the SoA serves as the primary verification document to prove:

- that risk treatment decisions were made logically and recorded.
- that each control is implemented and monitored.
- that non-applicable controls are rationally excluded with formal management approval.

Audit findings feed back into the PDCA “Check and Act” phases, improving ISMS performance over time.

12. Challenges and Solutions

Common Challenges	Solution / Best Practice
Complex mapping of Annex A controls organizational processes.	Use automated SoA tools integrated with risk registers and asset inventories.
Inconsistent rationale for control exclusions.	Establish a standardized “Control Decision Justification Template.”
Failure to update the SoA after organizational change.	Link SoA review triggers to Change Management Policy.
Poor awareness among control owners.	Conduct annual ISMS awareness training focused on control ownership.

13. Benefits of an Effective SoA

When implemented properly, the SoA delivers measurable business and security benefits:

- **Audit Readiness:** Streamlines ISO certification and re-certification processes.
- **Transparency:** Provides a single view of risk treatment and control status.
- **Accountability:** Links each control to responsible owners.
- **Efficiency:** Avoids redundant controls and enables cost-effective security management.
- **Continuous Improvement:** Feeds insights into training, policies, and strategic security initiatives.

Emphasizes that ISO 27001:2022’s new controls support enterprise resilience and digital trust goal achieved only when the SoA is treated as a strategic tool, not a checklist.

14. Example Summary Table for SoA Status Reporting

Control Category	No. of Controls	Applicable Controls	Implemented Controls	% Implemented
Organizational Controls (A.5–A.7)	37	33	30	91%
People Controls (A.8)	8	7	6	86%
Physical Controls (A.9)	14	12	11	92%
Technological Controls (A.10)	34	28	25	89%
Total	93	80	72	90% Implementation Rate

This summary provides management and auditors a clear snapshot of progress toward full compliance with ISO 27001:2022.

15. Conclusion

The Statement of Applicability stands as the backbone of the ISMS. It documents how organizational risks translate into specific, justified control decisions. By aligning the SoA with risk assessments, asset registries, and the PDCA cycle, organizations achieve transparent and auditable information security governance.

The SoA enables systematic traceability of security decisions from policy to practice and assures stakeholders that controls are selected based on objective risk evidence rather than assumptions.

A well-structured SoA is thus not a mere ISO requirement but a cornerstone of enterprise cyber resilience, governance maturity, and sustainable compliance with the ISO/IEC 27001:2022 standard.

References

Aleksandrov, Mark N. and Vasiliev, Victor A. and Aleksandrova, Svetlana V. (2021). Implementation of the Risk-based Approach Methodology in Information Security Management Systems. 2021 International Conference on Quality Management, Transport and Information Security, Information Technologies (IT&QM&IS), (pp. 137-139).

Guo, Huaqun and Wei, Meng and Huang, Ping and Chekole, Eyasu Getahun. (2021). Enhance Enterprise Security through Implementing ISO/IEC 27001 Standard. 2021 IEEE International Conference on Service Operations and Logistics, and Informatics (SOLI).

(Third edition 2022-10). ISO/IEC 27001:2022 - Information Security Management Standards, International Organization for Standardization. INTERNATIONAL STANDARD.

Malatji, Masike. (2023). Management of enterprise cyber security: A review of ISO/IEC 27001:2022. 2023 International Conference On Cyber Management And Engineering (CyMaEn).